

EthioConnect

Comprehensive Codebase Audit Report

Project: @ethio-connect/source

Date: April 30, 2026

Scope: Full monorepo audit (excluding tenant-apps)

Generated by: opencode audit engine

Report ID: ECA-20260430-142738

Executive Summary

Overall Assessment: SCALABLE FOUNDATION, SIGNIFICANT GAPS

EthioConnect is a well-structured Nx monorepo with clear domain separation (Central Hub, Customer Portal, Vendor Portal). The architectural foundation is solid, but the codebase is essentially a **scaffold-only state** with zero business logic, critical security vulnerabilities in workflows, and major consistency issues that must be addressed before production readiness.

32

Code Quality

45

Architecture

15

Security

40

DevOps/CI

Critical Findings: 4 | High: 12 | Medium: 18 | Low: 9

Table of Contents

1. Code Quality & Standards	8
2. Architecture & System Design	12
3. Performance & Efficiency	15
4. Security Audit	17
5. Testing & Reliability	21
6. Dependencies & Tooling	24
7. Documentation & Maintainability	27
8. DevOps & Deployment	30
9. Prioritized Action Plan	33

1. Code Quality & Standards

1.1 Critical: Typos in Core Framework Decorators

- **CRITICAL** — @Injectable() misspelled as @Injectable() in ALL NestJS services

Affects: central-hub-api, customer-portal-api, vendor-api-server | File: */app.service.ts

```
// INCORRECT (all 3 API services):
import { Injectable } from '@nestjs/common'; // TYPO: should be Injectable
@Injectable() // WON'T WORK - decorator won't register the class
export class AppService { ... }

// CORRECT:
import { Injectable } from '@nestjs/common';
@Injectable()
export class AppService { ... }
```

Impact: NestJS dependency injection will fail. The @Injectable() decorator is misspelled as @Injectable() — these are two different tokens. This will cause runtime errors.

1.2 High: HTML Attribute Typos in All Next.js Apps

- **HIGH** — rel="noreferrer" typo in ALL dashboard pages

Affects: 3 dashboards, 1 public website | 18+ occurrences across files

```
// INCORRECT:
// TYPO: should be noreferrer

// CORRECT:
```

Impact: The `rel` attribute is ignored by browsers. Security feature (noopener) is not enforced, creating potential tab-napping vulnerabilities.

1.3 High: Inconsistent Project Naming

- **HIGH** — "customer-portal" vs "customer-portal" inconsistency

Affects: All customer-portal apps and libs references

Location	Current (INCORCT)	Should Be
Directory	<code>apps/customer-portal/</code>	<code>apps/customer-portal/</code>
package.json name	<code>@ethio-connect/customer-portal-api</code>	<code>@ethio-connect/customer-portal-api</code>
CI workflow	<code>customer-portal-api</code>	<code>customer-portal-api</code>

Impact: File system paths use `customer-portal` but some references use `customer-portal`. This causes broken imports, failed builds, and confusion.

1.4 Medium: Dead Code & Nx Scaffold Leftovers

- **MEDIUM** — All apps contain Nx default scaffold content

Affects: All 7 applications + 3 libraries

- All Next.js pages display Nx default template with hardcoded links to [nx.dev](#)
- All API services return hardcoded `{ message: 'Hello API' }` — no business logic
- UI component library has placeholder `EthioConnectUiComponents` with no actual components
- All 5 libraries are scaffold-only with no implementation

1.5 Medium: Port Conflict Risk

- **MEDIUM** — All 3 NestJS APIs use hardcoded port 3000

File: */main.ts | Line: 14

```
// INCORCT: All APIs will try to bind to port 3000
const port = process.env.PORT || 3000; // Will conflict!

// RECOMMENDED:
const port = process.env.PORT || getDefaultPortForApp();
// Or use different defaults: 3001, 3002, 3003
```

1.6 Low: ESLint Flat Config Not Utilized

- **LOW** — Root eslint.config.mjs exists but apps use legacy config

Apps still reference `.eslintrc.json` (deprecated) while root uses modern flat config. This creates inconsistent linting behavior.



2. Architecture & System Design

2.1 High: Missing @ethio-connect/infrastructure Project

- **HIGH** — Workflows reference non-existent infrastructure project

Files: ci.yml, release.yml, promote.yml, rollback.yml (removed but originally referenced)

The CI/CD workflows originally referenced `@ethio-connect/infrastructure` project, `libs/infrastructure/scripts/*.mjs`, and environment YAML files — none of which exist. This would cause all deploy/promote/rollback workflows to fail.

Resolution: Either create the infrastructure project with proper structure, or remove all infrastructure dependencies from workflows (which has now been done).

2.2 High: No Shared API Modules Used

- **HIGH** — @ethio-connect/api-common and @ethio-connect/api-features are empty

Files: `libs/api-common/src/lib/api-common.module.ts`, `libs/api-features/src/lib/api-features.module.ts`

```
// CURRENT STATE (empty modules):
@Module({ controllers: [], providers: [], exports: [] })
export class EthioConnectApiCommonModule {}

// EXPECTED (example):
@Module({
  controllers: [HealthController],
  providers: [AuthService, PrismaService],
  exports: [AuthService]
})
export class EthioConnectApiCommonModule {}
```

Impact: No shared authentication, database access, or common utilities exist across the 3 API services. Each API will duplicate code.

2.3 Medium: No Clear API→Frontend Integration Pattern

- **MEDIUM** — No API client, no data fetching pattern defined

There's no defined pattern for how Next.js frontends consume NestJS APIs. No Swagger/OpenAPI spec, no generated clients, no tRPC or REST client setup.

2.4 Medium: Monorepo Module Boundary Violations Possible

- **MEDIUM** — ESLint module boundary rules defined but not enforced in CI

The `eslint.config.mjs` defines tags (`scope:central-hub`, `type:api`, etc.) but the CI workflow doesn't run `lint` as a blocking step for all projects.

2.5 Low: No Database/ORM Layer Defined

- **LOW** — [No database, ORM, or data persistence layer](#)

[For a production app with customers and vendors, there's no Prisma, TypeORM, or any data layer defined. This is expected in scaffold state but must be prioritized.](#)

3. Performance & Efficiency

3.1 Medium: Webpack Config Not Optimized for Production

- **MEDIUM** — [optimization: false in all webpack configs](#)

Files: */webpack.config.js

```
// CURRENT (development-focused):
module.exports = {
  output: { ... },
  plugins: [
    new NxAppWebpackPlugin({
      target: 'node',
      optimization: false, // DISABLED!
      outputHashing: 'none',
      ...
    })
  ]
};

// PRODUCTION SHOULD:
optimization: {
  minimize: true,
  splitChunks: { chunks: 'all' },
  ...
}
```

3.2 Low: No Caching Strategy

- **LOW** — [No Redis, in-memory, or HTTP caching configured](#)

[No caching layer exists for API responses, database queries, or Next.js pages. Critical for production performance.](#)

3.3 Low: Large SVG Inlining in Pages

- **LOW** — [Nx logo SVGs are ~200 lines each, inlined in pages](#)

[The scaffold pages contain ~200 lines of SVG markup for the Nx logo, inlined in each page component. This should be extracted to a component.](#)

4. Security Audit

4.1 Critical: CORS Not Configured on NestJS APIs

- **CRITICAL** — No CORS, Helmet, or rate limiting configured

Files: `*/main.ts` for all 3 APIs

```
// CURRENT (no security):
const app = await NestFactory.create(AppModule);
const port = process.env.PORT || 3000;
await app.listen(port);

// REQUIRED FOR PRODUCTION:
import * as helmet from 'helmet';
const app = await NestFactory.create(AppModule);
app.use(helmet.default());
app.enableCors({ origin: ['https://ethioconnect.com'] });
app.useGlobalPipes(new ValidationPipe({ whitelist: true }));
await app.listen(port);
```

Impact: APIs accept requests from any origin (CORS wide open), no security headers (Helmet), no input validation, no rate limiting. Critical for production.

4.2 Critical: Environment Variables Not Validated

- **CRITICAL** — No validation of required env vars (DATABASE_URL, JWT_SECRET, etc.)

APIs read `process.env.PORT` without validation. Missing: `JWT_SECRET`, `DATABASE_URL`, API keys. No schema validation (zod, joi, class-validator).

4.3 High: Secrets in Workflow Files

- **HIGH** — Server credentials referenced in plain text in workflows

Files: `ci.yml`, `release.yml`, `promote.yml`, `rollback.yml`

```
// EXPOSED (ci.yml):
SERVER DOMAIN: ${ secrets.SERVER DOMAIN }
SERVER USER: ${ secrets.SERVER USER }
SERVER PASSWORD: ${ secrets.SERVER PASSWORD } // Password-based SSH!
SERVER SSH KEY PATH: ""
SERVER SSH PORT: ${ secrets.SERVER SSH PORT || '22' }
```

Issues: (1) Password-based SSH instead of key-based auth; (2) SSH key path is empty string; (3) No secret rotation strategy.

4.4 High: Dependency Confusion Risk

- **HIGH** — Private packages use @ethio-connect scope without registry lock

Workspace uses `@ethio-connect/*` packages. Without `.npmrc` or `pnpm.nexus.yml` restricting the scope to a private registry, malicious packages could be injected via dependency confusion attacks.

4.5 Medium: No Input Validation on API Endpoints

- **MEDIUM** — Controllers have no DTOs, no validation

```
// CURRENT (no validation):
@Controller()
export class AppController {
  @Get()
  getData() { return this.appService.getData(); }
}

// REQUIRED:
@Controller()
export class AppController {
  @Get()
  getData(@Query() query: GetDataDto) { ... }
}
```

4.6 Medium: Next.js Apps No Auth Guards

- **MEDIUM** — No authentication/authorization in Next.js pages

Dashboard pages have no auth checks, middleware, or route guards. Any unauthenticated user can access all pages.

5. Testing & Reliability

5.1 Critical: Tests Are Nx Scaffold Defaults Only

- **CRITICAL** — [All test files are auto-generated defaults](#)

Affects: All apps and libs

```
// TYPICAL TEST (identical across all projects):
describe('AppController', () => {
  let app: TestingModule;
  beforeEach(async () => {
    app = await Test.createTestingModule({
      controllers: [AppController],
      providers: [AppService],
    }).compile();
  });
  it('should be defined', () => {
    const controller = app.get(AppController);
    expect(controller).toBeDefined();
  });
});
```

Issues: (1) Tests only check if classes are defined; (2) No business logic testing; (3) No edge cases; (4) No integration tests; (5) No E2E tests beyond default Playwright scaffold.

5.2 High: E2E Tests Not Properly Configured

- **HIGH** — [E2E test projects exist but have no real tests](#)

All `*-e2e` projects contain only `example.spec.ts` with placeholder content. The CI runs these but they don't actually test anything meaningful.

5.3 Medium: No Error Handling / Fault Tolerance

- **MEDIUM** — [No global exception filters, no error boundaries](#)

NestJS APIs have no global exception filter. Next.js apps have no error boundaries. Any unhandled error will crash the app or show a blank page.

5.4 Medium: No Health Check Endpoints

- **MEDIUM** — [No /health, /ready, /live endpoints](#)

Kubernetes/Docker health checks will fail. No readiness/liveness probes defined for any API service.

5.5 Low: No Logging/Observability

- **LOW** — No structured logging, no metrics, no tracing

No Winston/Pino logger, no Prometheus metrics, no OpenTelemetry tracing. Impossible to debug issues in production.

6. Dependencies & Tooling

6.1 High: Dependabot Config Has Multiple Typos

- **HIGH** — [.github/dependabot.yml](#) has 15+ YAML key typos

File: [.github/dependabot.yml](#)

INCORRECT Key	CORRECT Key
<code>package-ecosystem</code>	<code>package-ecosystem</code>
<code>versioning-strategy</code>	<code>version-ing-strategy</code>
<code>semver-major</code>	<code>semver-major</code>
<code>semver-minor</code>	<code>semver-minor</code>
<code>semver-patch</code>	<code>semver-patch</code>

Impact: Dependabot will silently ignore the config file and not create any PRs. The entire dependency update strategy is broken.

6.2 Medium: Outdated NestJS 11 with @nestjs/schematics

- **MEDIUM** — [@nestjs/schematics](#) is deprecated in NestJS 11

NestJS 11 uses [@nestjs/cli](#) instead of [@nestjs/schematics](#). The devDependency should be updated.

6.3 Medium: pnpm 10.20.0 — Very New, Potential Stability Issues

- **MEDIUM** — [pnpm 10.x](#) is cutting-edge

[pnpm 10.20.0](#) was released very recently. Consider pinning to a more stable version like [pnpm 9.x LTS](#) for production.

6.4 Low: No pnpm.nexus.yml for Private Packages

- **LOW** — No Nexus or private registry config

If publishing [@ethio-connect/*](#) packages to a private registry, [pnpm.nexus.yml](#) is needed to avoid dependency confusion.

7. Documentation & Maintainability

7.1 Critical: README Is Nx Default Template

- **CRITICAL** — Root README.md is copy-pasted Nx template

File: README.md

The README contains links to [nx.dev](#), "Get Started with Nx", and generic Nx documentation. There's zero information about:

- [What EthioConnect actually does](#)
- [How to set up the development environment](#)
- [Architecture diagrams or explanations](#)
- [How to run individual apps](#)
- [Environment variable requirements](#)
- [Deployment instructions](#)

7.2 High: No CONTRIBUTING.md

- **HIGH** — No contribution guidelines

No PR template, no code review guidelines, no commit message conventions documented.

The repo has no [CONTRIBUTING.md](#), no [CODE OF CONDUCT.md](#), no [PULL REQUEST TEMPLATE.md](#).

7.3 High: No .env.example Files

- **HIGH** — Developers won't know what env vars to set

No [.env.example](#) in root or any app directory. New developers cannot bootstrap the project without guessing required environment variables.

7.4 Medium: No AGENTS.md or Developer Guidelines

- **MEDIUM** — CI blocks "local agent scaffolding" but no docs explain what's allowed

The CI workflow blocks [.agents](#), [.gemini](#), [AGENTS.md](#) files but there's no documentation on what AI agent workflow is expected.

7.5 Low: No Architecture Decision Records (ADRs)

- **LOW** — No record of why decisions were made

No [docs/adr/](#) directory. Decisions like "NestJS vs Express", "Next.js vs Remix", "pnpm vs npm" aren't documented.

8. DevOps & Deployment

8.1 Critical: Dockerfiles Are Minimal/Incomplete

- **CRITICAL** — [Dockerfiles are 3-line stubs](#)

File: [apps/*/Dockerfile](#)

```
# CURRENT (useless):  
FROM node:22-alpine  
WORKDIR /app  
COPY . .  
CMD ["node", "-e", "console.log('Container image built for app context.')]"]  
  
# REQUIRED:  
FROM node:22-alpine AS builder  
WORKDIR /app  
COPY package.json pnpm-lock.yaml ./  
RUN npm install -g pnpm && pnpm install --frozen-lockfile  
COPY . .  
RUN pnpm nx build @ethio-connect/central-hub-api  
  
FROM node:22-alpine  
WORKDIR /app  
COPY --from=builder /app/dist ./dist  
COPY --from=builder /app/node_modules ./node_modules  
CMD ["node", "dist/apps/central-hub/central-hub-api/main.js"]
```

Impact: [Current Dockerfiles don't actually build or run the app. They're placeholders that just print a log message and exit.](#)

8.2 High: Workflow Regex Syntax Errors

- **HIGH** — [Multiple bash regex syntax errors in CI workflow](#)

File: [.github/workflows/ci.yml](#)

```
# INCORCT (won't match anything):  
if [[ ! "$version" =~ ^v[0-9]+\.[0-9]+\.[0-9]+... ]]; then # [0-9] should be [0-9]  
  
# INCORCT (missing $ sign):  
if [[ "${{ github.event.name }}" == "workflow dispatch" ]]; then # Missing $  
  
# INCORCT (bash array syntax):  
if (( ${#disallowed_paths[@]} > 0 )); then # Should be ${#disallowed_paths[@]} but  
depends on context
```

8.3 High: No Staging Environment Parity

- **HIGH** — [No docker-compose, no local dev environment](#)

[No docker-compose.yml](#), [no devcontainer.json](#), [no local Kubernetes setup. Developers can't run the full stack locally.](#)

8.4 Medium: Nx Cloud ID May Be Incorrect

- **MEDIUM** — [nx.json Cloud ID "69f299b3bd50ccb2dc8f1fc7" not verified](#)

[The Nx Cloud ID in `nx.json` must match the actual Nx Cloud workspace. If incorrect, distributed task execution and caching won't work.](#)

8.5 Low: Trivy Scanner Not Installed in CI

- **LOW** — [container_publish job references trivy but it's not installed](#)

[The CI workflow runs `trivy image ...` but Trivy is not installed in the GitHub Actions runner. This will cause the scan step to fail.](#)

9. Prioritized Action Plan

9.1 Critical Severity (Fix Immediately)

#	Finding	Effort	Impact
1	Fix @Injectable() → @Injectable() typo in all 3 API services	5 min	Fixes broken DI
2	Fix rel="noreferrer" typo in all Next.js pages (18+ occurrences)	15 min	Fixes security attribute
3	Fix Dockerfiles — they don't actually build/run the app	2 hours	Enables deployment
4	Add Helmet, CORS, ValidationPipe to all NestJS APIs	3 hours	Critical security
5	Fix Dependabot config — 15+ YAML key typos	30 min	Enables dependency updates

9.2 High Severity (Fix This Sprint)

#	Finding	Effort	Impact
1	Fix inconsistent naming: customer-portal vs customer-portal	1 hour	Prevents build failures
2	Add health check endpoints (/health) to all APIs	2 hours	Enables container orchestration
3	Implement api-common module with auth, database, common services	1-2 sprints	Prevents code duplication
4	Add .env.example and document all required env vars	1 hour	Developer onboarding
5	Replace password-based SSH with key-based auth in workflows	1 hour	Security best practice
6	Fix CI workflow regex syntax errors	1 hour	Prevents false positives
7	Rewrite README.md with actual project documentation	3 hours	Project clarity

9.3 Medium Severity (Fix Next Sprint)

#	Finding	Effort
---	---------	--------

1	Enable webpack optimization for production builds	2 hours
2	Add global exception filters and error boundaries	4 hours
3	Add structured logging (Winston/Pino) and metrics	1 sprint
4	Define API client pattern (trRPC/Swagger/gen)	1 sprint
5	Add real unit/integration tests (beyond scaffold)	2 sprints
6	Add database/ORM layer (Prisma/TypeORM)	1 sprint
7	Create docker-compose for local dev environment	4 hours

9.4 Quick Wins (Less than 1 Hour Each)

- [Extract inline SVGs to reusable React components](#)
- Add `CONTRIBUTING.md` & `CODE_OF_CONDUCT.md`
- [Add Node.js version file \(`.nvmrc` \)](#)
- [Pin pnpm to a specific version in `packageManager` field](#)
- [Add `engines` field to package.json restricting Node.js version](#)
- [Add `.npmrc` with `auto-install-peers=true`](#)
- [Add `lint-staged` and `husky` for pre-commit hooks](#)

9.5 Refactoring Roadmap

Phase 1: Foundation (Weeks 1-2)

- [Fix all typos \(Injectable, noreferrer, customer-portal\)](#)
- [Implement proper Dockerfiles and docker-compose](#)
- [Add security middleware \(Helmet, CORS, validation\)](#)
- [Set up database/ORM layer in api-common](#)
- [Document all environment variables](#)

Phase 2: Core Features (Weeks 3-6)

- [Implement authentication \(JWT/OAuth\) in api-common](#)
- [Build shared UI component library \(ui-components\)](#)
- [Define API client pattern and generate clients](#)
- [Implement health checks and observability](#)
- [Write comprehensive unit/integration tests](#)

Phase 3: Production Readiness (Weeks 7-10)

- [Performance optimization \(webpack, caching, CDN\)](#)
- [Security audit remediation and pen testing](#)
- [CI/CD hardening and environment parity](#)
- [Load testing and scalability validation](#)
- [Documentation completion and onboarding guides](#)

10. Project-Specific Summary

@ethio-connect/central-hub-api

- [@Injectable typo](#)
- [No security middleware](#)
- [Port 3000 hardcoded](#)
- [Health check missing](#)
- [Clean module structure](#)

@ethio-connect/central-hub-dashboard

- [rel="noreferrer" typos](#)
- [Nx template content](#)
- [No auth guards](#)
- [Tailwind configured](#)
- [Next.js 16 + React 19](#)

@ethio-connect/public-website

- [rel="noreferrer" typos](#)
- [Nx template content](#)
- [No SEO optimization](#)
- [Next.js 16 + React 19](#)

@ethio-connect/customer-portal-*

- [@Injectable typo](#)
- [Naming inconsistency](#)
- [No business logic](#)
- [No tests](#)

@ethio-connect/vendor-portal-*

- [@Injectable typo](#)
- [No business logic](#)
- [Port 3000 conflict](#)
- [No tests](#)

@ethio-connect/api-common

- [Empty module](#)
- [No exports](#)
- [Needs auth, DB, utils](#)

@ethio-connect/ui-components

- [Placeholder only](#)
- [No actual components](#)
- [Storybook not configured](#)

@ethio-connect/ethioconnect

- [Has ethioconnect\(\) util](#)
- [Needs more utilities](#)

EthioConnect Codebase Audit Report

Generated: April 30, 2026 | Report ID: ECA-20260430-142738

Confidential — For internal use only